

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 01

Domain IV - Incident Management

43 Questions	69 Minutes	Single Best Answer Format
------------------------	----------------------	-------------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 69 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM1-108)

Scenario: A global manufacturer has regional incident procedures, but a recent exercise showed that nobody knew who could isolate a production network when the plant manager was unavailable.

Which improvement would BEST address the readiness weakness?

- A. Define delegated isolation authority, alternates, and escalation conditions in the incident response plan.
- B. Require the security operations team to obtain executive approval for every network change.
- C. Add more technical indicators to the monitoring platform before revising the plan.
- D. Transfer all incident decisions to the plant's network service provider.

Question 2 (CISM1-109)

Which condition is the MOST important trigger for reviewing an incident response plan outside its scheduled review cycle?

- A. The security team adopts a new internal meeting format.
- B. The organization changes the color scheme of its awareness materials.
- C. A major acquisition changes critical services, reporting lines, and regulatory obligations.
- D. A vendor publishes a routine update to a noncritical utility.

Question 3 (CISM1-110)

Scenario: A financial cooperative's cyber incident plan works well for technical events, but it does not specify when a disruption should move to enterprise crisis leadership.

What should the information security manager add to the plan?

- A. A requirement that every security alert activate the crisis team.
- B. Business-impact thresholds and a defined handoff and coordination process for crisis activation.
- C. A rule that the incident commander becomes the permanent crisis leader.
- D. Detailed instructions for analysts to configure every security tool.

Question 4 (CISM1-111)

Scenario: A health services group has separate response plans for corporate systems, clinics, and a cloud platform. Each plan assigns different severity owners and uses incompatible escalation criteria.

Which action would provide the GREATEST improvement?

- A. Allow each technical team to retain its criteria to preserve local flexibility.
- B. Replace the plans with a single set of detailed technical procedures.
- C. Ask internal audit to assume incident command whenever ownership is disputed.
- D. Establish an enterprise response framework with common governance, severity principles, interfaces, and accountable owners.

Question 5 (CISM1-112)

Scenario: An online marketplace lists its payment service as critical, but the business impact analysis does not document its dependencies on identity, fraud screening, or telecommunications.

What is the MOST significant incident-readiness concern?

- A. The response team may collect too many technical logs.
- B. The payment service may have a lower annual support cost than expected.
- C. Response and recovery priorities may fail because prerequisite services are not identified.
- D. The marketplace may classify every payment alert as a disaster.

Question 6 (CISM1-113)

Scenario: A university is updating response playbooks. Student registration has severe impact during two short enrollment periods but modest impact during most of the year.

How should this information be reflected in readiness planning?

- A. Use time-sensitive impact criteria that raise priority during enrollment windows.
- B. Assign one fixed low severity because annual average impact is modest.
- C. Treat the service as continuously critical regardless of business timing.
- D. Base severity only on the number of servers supporting registration.

Question 7 (CISM1-114)

Scenario: A distribution company has approved a four-hour recovery time objective for warehouse dispatch but has never established how much transaction data it can afford to lose.

Which requirement should be defined NEXT?

- A. The service desk's average time to close ordinary tickets.
- B. A recovery point objective based on acceptable dispatch-data loss.
- C. A target number of security alerts reviewed each day.
- D. The maximum duration of the annual recovery exercise.

Question 8 (CISM1-115)

What is the PRIMARY purpose of coordinating business continuity planning with incident management?

- A. To make the continuity team responsible for forensic analysis.
- B. To ensure every security event causes relocation to an alternate site.
- C. To replace the incident response plan with business workarounds.
- D. To sustain priority business activities during containment and service restoration.

Question 9 (CISM1-116)

Scenario: A utility plans to use emailed spreadsheets as a manual workaround if its scheduling platform is unavailable. The same email environment depends on the identity service most likely to be disabled during a suspected account compromise.

What should the information security manager recommend?

- A. Develop and test a workaround without the likely failed dependency.
- B. Accept the workaround because spreadsheets require no application server.
- C. Increase the scheduling platform's severity rating without changing the workaround.
- D. Prohibit all manual processing during security incidents.

Question 10 (CISM1-117)

Scenario: A call center can operate manually for six hours. Its response plan only says continuity procedures begin when the application is declared permanently unavailable.

Which change is MOST appropriate?

- A. Delay continuity activation until technical recovery has failed.
- B. Activate continuity for every degradation lasting more than five minutes.
- C. Define impact- and duration-based triggers that preserve the six-hour business tolerance.
- D. Allow individual agents to choose when continuity procedures begin.

Question 11 (CISM1-118)

Scenario: A media company intends to recover its publishing application before restoring name resolution and privileged identity services required by that application.

What is the BEST response to this plan?

- A. Approve it because customer-facing applications always recover first.
- B. Revise the recovery sequence to restore prerequisite services before the publishing application.
- C. Set the same recovery time objective for every supporting component.
- D. Move responsibility for business priorities entirely to infrastructure engineers.

Question 12 (CISM1-119)

Scenario: A retailer's disaster recovery test reports success after virtual machines start at the alternate site. No business transactions or interfaces are tested.

What should be added to the NEXT exercise?

- A. A larger inventory of virtual machine configuration files.
- B. A demonstration that backup jobs began at the scheduled time.
- C. A review of the alternate site's office seating plan.
- D. End-to-end validation of prioritized services, data integrity, interfaces, and recovery objectives.

Question 13 (CISM1-120)

Which element is MOST essential for converting business recovery priorities into an actionable disaster recovery plan?

- A. Documented restoration sequences, dependencies, responsibilities, and validation criteria.
- B. A complete history of all routine service desk incidents.
- C. A list of every employee's preferred communication channel.
- D. A policy requiring all systems to recover simultaneously.

Question 14 (CISM1-121)

Scenario: A software firm classifies incidents solely by the number of affected devices. An unauthorized change to one code-signing server is therefore rated lower than adware on hundreds of employee laptops.

Which revision would BEST improve classification?

- A. Base every incident on the financial value of the hardware involved.
- B. Include data sensitivity, service criticality, trust impact, scope, and urgency in severity criteria.
- C. Let the first analyst choose severity without documented guidance.
- D. Classify every integrity issue at the maximum severity.

Question 15 (CISM1-122)

Scenario: A laboratory's response procedure tells analysts to escalate any event that seems serious. Recent exercises produced inconsistent legal and executive involvement.

What should replace this instruction?

- A. Escalation only after the full root cause has been proven.
- B. Escalation whenever any employee requests management attention.
- C. Documented thresholds based on impact, affected information, operational risk, and applicable obligations.
- D. Automatic executive escalation of every security alert.

Question 16 (CISM1-123)

Scenario: A public agency uses one label, high priority, for outages, suspected privacy incidents, minor malware infections, and physical access violations. Responders frequently involve the wrong specialists.

Which redesign is MOST effective?

- A. Separate category and severity, then map both to response requirements.
- B. Create a unique severity level for every technology platform.
- C. Use only the estimated time required for technical repair.
- D. Retain one label but distribute it to more recipients.

Question 17 (CISM1-124)

Scenario: A transportation company's response team is technically capable, but an exercise reveals confusion about regulatory liaison, operational safety, and executive briefings.

What should the information security manager do NEXT?

- A. Provide malware-analysis training to every executive.
- B. Replace the entire technical response team.
- C. Limit future exercises to technology restoration tasks.
- D. Map competencies to roles and train identified gaps.

Question 18 (CISM1-125)

Scenario: An insurer repeats the same announced tabletop scenario each quarter. Participants know every inject and consistently report perfect performance.

How should the exercise program be improved?

- A. Stop documenting results because performance is stable.
- B. Vary realistic scenarios and injects to test objectives, decisions, dependencies, and unexpected developments.
- C. Score success only by how quickly the technical team identifies the simulated attack.
- D. Exclude business leaders so future results measure security performance alone.

Question 19 (CISM1-126)

Which exercise is BEST suited to examining senior leaders' decisions and coordination in a complex incident without disrupting production?

- A. An unannounced shutdown of all production systems.
- B. A review limited to whether responder contact numbers are current.
- C. A facilitated tabletop exercise using progressive business and stakeholder injects.
- D. A technical vulnerability scan of the production environment.

Question 20 (CISM1-127)

Scenario: A food processor completes a full-scale simulation. The report lists participant attendance and says the team communicated well, but it contains no evidence tied to exercise objectives.

What should the information security manager require?

- A. Objective-based observations, identified gaps, accountable corrective actions, and retesting criteria.
- B. A higher attendance target as the sole measure of response capability.
- C. Deletion of negative observations to encourage future participation.
- D. Immediate certification of the plan because the simulation was completed.

Question 21 (CISM1-128)

What is the PRIMARY purpose of initial incident triage?

- A. To complete root-cause analysis before any response action.
- B. To identify incidents and establish their initial priority and routing.
- C. To authorize public disclosure for every confirmed alert.
- D. To restore all affected systems before evidence is collected.

Question 22 (CISM1-129)

Scenario: During a holiday weekend, a hospital receives two reports: repeated blocked scans against a public website and unexplained medication-order changes in one clinical unit.

Which report should receive FIRST priority?

- A. The blocked scans, because they involve more individual connections.
- B. Both reports equally, because every alert has the same initial impact.
- C. Neither report until the regular security manager returns.
- D. The medication-order changes, because potential integrity and patient-safety impact require urgent assessment.

Question 23 (CISM1-130)

Scenario: Employees at a construction group report suspicious activity through personal messages to whichever technician they know. Several credible reports were missed when recipients were off duty.

What is the MOST appropriate management action?

- A. Ask employees to send reports to more individual technicians.
- B. Accept reports only after employees collect definitive proof.
- C. Establish well-publicized, monitored reporting channels with defined intake and escalation procedures.
- D. Require business managers to investigate reports before security receives them.

Question 24 (CISM1-131)

Scenario: A control workstation at a chemical facility is behaving unpredictably. Plant engineers believe it may create an immediate safety hazard, while investigators want it left untouched to preserve volatile evidence.

What should the information security manager support FIRST?

- A. Safely stabilize the process while preserving evidence where feasible.
- B. Keep the workstation operating until investigators capture every possible artifact.
- C. Erase the workstation immediately without documenting actions.
- D. Allow the software vendor to decide whether plant safety procedures apply.

Question 25 (CISM1-132)

Scenario: Evidence suggests a senior administrator may have misused privileged access. The administrator's manager proposes that the administrator collect and interpret all relevant logs because of specialized knowledge.

What is the BEST course of action?

- A. Accept the proposal but ask the administrator for a verbal summary.
- B. Suspend the investigation until the administrator agrees with its scope.
- C. Use independent investigators and coordinate authorized access with legal and HR.
- D. Publicly identify the administrator before validating the evidence.

Question 26 (CISM1-133)

Scenario: After suspected payment fraud, several teams copied transaction records to personal drives without recording who collected them, when they were copied, or how they were stored.

What is the MOST significant concern?

- A. The records will necessarily prove the wrong root cause.
- B. Evidence integrity may be challenged because custody was undocumented.
- C. The incident must automatically be reclassified as a disaster.
- D. The recovery time objective must be shortened immediately.

Question 27 (CISM1-134)

Scenario: A nonprofit confirms that a former contractor downloaded donor records. Litigation is reasonably anticipated, and investigators are ready to begin interviews.

What should the information security manager do NEXT?

- A. Let each investigator decide independently what to retain.
- B. Contact all donors before the scope and notification obligations are assessed.
- C. Delete unrelated records to reduce the volume of material reviewed.
- D. Coordinate with legal counsel on preservation, interview, privilege, and documentation requirements.

Question 28 (CISM1-135)

Which factor should MOST influence the selection of an incident containment strategy?

- A. The personal preference of the first responder.
- B. Balancing ongoing harm, safety, business impact, evidence, and recovery needs.
- C. The number of pages in the technical procedure.
- D. Whether the containment action was used in the previous incident.

Question 29 (CISM1-136)

Scenario: A logistics provider confirms that a partner connection is sending malformed records that corrupt routing data. Disconnecting the partner will delay some shipments, but leaving it active will continue spreading bad data.

What is the BEST containment decision?

- A. Isolate the connection, preserve records, and activate the authorized shipment workaround.
- B. Keep the connection active until no shipment delay is possible.
- C. Rebuild every routing system before stopping the corrupt input.
- D. Ask the partner to decide whether the organization's data should be protected.

Question 30 (CISM1-137)

Scenario: A municipal service relies on an unsupported application with a confirmed exploitable flaw. Immediate replacement is impossible, and full shutdown would interrupt an essential public service.

Which approach is MOST appropriate after immediate exposure has been reduced?

- A. Restore all prior connectivity because short-term containment succeeded.
- B. Accept the risk permanently without management approval.
- C. Use time-bound compensating controls and track a permanent replacement.
- D. Conceal the limitation from service owners until replacement is complete.

Question 31 (CISM1-138)

Scenario: A rumor on social media claims that an airline lost all passenger records. The incident team has confirmed a service interruption but has not established data loss.

What should the communications lead do?

- A. Confirm the rumored data loss to appear responsive.
- B. Release detailed technical hypotheses from individual investigators.
- C. Remain silent until root cause analysis is complete, regardless of operational impact.
- D. Issue an approved factual holding statement with response actions and update channels.

Question 32 (CISM1-139)

Scenario: A regional lender discovers possible exposure of customer information across several jurisdictions. The data elements and affected individuals are still being determined.

What should the information security manager do FIRST regarding notification?

- A. Engage legal and privacy stakeholders to map verified facts to applicable notification requirements.
- B. Use the shortest notification deadline found online as a universal rule.
- C. Notify every customer immediately that identity theft has occurred.
- D. Wait for complete root-cause analysis before assessing any obligation.

Question 33 (CISM1-140)

Scenario: During a cloud outage caused by unauthorized configuration changes, executives receive raw alert exports while engineers receive vague statements about reputational risk. Both groups complain that updates are unusable.

What is the BEST improvement?

- A. Send identical technical detail to every stakeholder to ensure consistency.
- B. Use verified facts and tailor approved updates to each audience's decision needs.
- C. Allow each response team to publish independent estimates.
- D. Stop scheduled updates and respond only to individual questions.

Question 34 (CISM1-141)

Scenario: A telecommunications outage has expanded beyond technical recovery estimates and is disrupting emergency call routing in multiple regions. The incident team is still operating under routine status-reporting procedures.

What should the information security manager do NEXT?

- A. Continue routine reporting until engineers determine the root cause.
- B. Ask individual responders to answer media inquiries directly.
- C. Escalate under the crisis plan and coordinate operational, executive, regulatory, and public communications.
- D. Close the security incident because the main impact is now operational.

Question 35 (CISM1-142)

Scenario: A professional services firm removed a malicious browser extension from affected laptops. Investigators also found that the incident created unauthorized identity tokens that remain valid.

What should occur before normal access is restored?

- A. Declare eradication complete because the visible software was removed.
- B. Restore access and revoke tokens at the next scheduled maintenance window.
- C. Close the incident and address identity tokens as routine support tickets.
- D. Revoke unauthorized tokens, remediate the weakness, and validate removal of persistence.

Question 36 (CISM1-143)

What is the PRIMARY purpose of validating a recovered service before returning it to normal operation?

- A. To verify service functionality, integrity, security, and required business outcomes.
- B. To prove that the original incident could never recur.
- C. To eliminate the need for enhanced monitoring after restoration.
- D. To transfer recovery acceptance entirely to the technology vendor.

Question 37 (CISM1-144)

Scenario: A payroll platform has been rebuilt after unauthorized database changes. Technical checks pass, but reconciliation shows unexplained differences in a small set of employee balances.

Who should authorize return to normal processing, and on what basis?

- A. The system administrator immediately because infrastructure checks passed.
- B. The business owner and incident authority, after agreed recovery criteria are met.
- C. The external software supplier based only on application availability.
- D. Any response team member once the recovery time objective is reached.

Question 38 (CISM1-145)

Scenario: An e-commerce company has restored a service after credential abuse. Passwords and tokens were reset, the application passed validation, and the root access path appears closed.

What is the MOST appropriate next step?

- A. Disable security logging to improve recovered-service performance.
- B. Immediately dissolve the response team and delete incident indicators.
- C. Restore service gradually with enhanced monitoring for recurrence.
- D. Keep the service offline until every enterprise risk is eliminated.

Question 39 (CISM1-146)

Scenario: After containing an impersonation incident involving synthetic audio, a charity's review finds that its risk assessment and response exercises address only email impersonation. Several executives also bypassed the established callback process.

Which improvement package would BEST address the lessons learned?

- A. Record the event as unusual but leave the risk assessment and exercises unchanged.
- B. Reassess the risk, revise procedures, train affected roles, and test a new scenario.
- C. Rely only on a technical filter because executive decisions are outside incident management.
- D. Prohibit all executive voice communications during future incidents.

Question 40 (CISM1-147)

Scenario: After an accidental exposure, a director wants the post-incident meeting to focus exclusively on identifying the employee who made the final configuration change.

How should the information security manager respond?

- A. Cancel the review because human error cannot be prevented.
- B. Agree, because disciplinary action is the primary purpose of a post-incident review.
- C. Exclude process owners so the meeting remains confidential.
- D. Examine process, design, oversight, and contributing conditions while handling individual accountability through appropriate channels.

Question 41 (CISM1-148)

Scenario: A warehouse outage began when a certificate expired. The review finds that renewal ownership was undefined, alerts went to a retired mailbox, and no preproduction expiry test existed.

Which finding BEST represents the root-cause focus?

- A. The lifecycle process failed to establish ownership, monitoring, and effective testing.
- B. Users could not access the warehouse application during the outage.
- C. Responders restarted several servers during diagnosis.
- D. The help desk received an unusually high number of calls.

Question 42 (CISM1-149)

Scenario: Six months after a supply-chain incident, the review's recommendations remain in meeting notes. Several were discussed, but no owner, due date, or evidence of completion exists.

What should the information security manager implement?

- A. Close all recommendations because the incident is no longer active.
- B. Ask vendors to certify completion without organizational review.
- C. A tracked corrective-action process with owners, deadlines, validation, and exception governance.
- D. Retain the notes as the only evidence that improvement occurred.

Question 43 (CISM1-150)

Scenario: A technology company reports only the total number of incidents each month. Leadership cannot tell whether response capability or recurring control weaknesses are improving.

Which metric set would provide the MOST useful management insight?

- A. Only the number of alerts generated by each monitoring tool.
- B. Only the hours worked by responders during major incidents.
- C. Only the number of incidents closed before month-end.
- D. Trends in impact, response times, recurrence, corrective-action aging, and recovery performance.

Answer Key

Domain IV - Incident Management

1 A	2 C	3 B	4 D	5 C
6 A	7 B	8 D	9 A	10 C
11 B	12 D	13 A	14 B	15 C
16 A	17 D	18 B	19 C	20 A
21 B	22 D	23 C	24 A	25 C
26 B	27 D	28 B	29 A	30 C
31 D	32 A	33 B	34 C	35 D
36 A	37 B	38 C	39 B	40 D
41 A	42 C	43 D		

Detailed Explanations

Question 1 (CISM1-108)

Correct answer: A - Define delegated isolation authority, alternates, and escalation conditions in the incident response plan.

At the readiness phase, documented delegated authority and alternates enable timely action when a primary decision maker is absent. Executive approval for every change creates delay, additional indicators do not solve the authority gap, and outsourcing decisions does not remove management accountability.

Question 2 (CISM1-109)

Correct answer: C - A major acquisition changes critical services, reporting lines, and regulatory obligations.

A major acquisition can invalidate scope, authority, contacts, dependencies, and notification requirements, so it warrants an immediate plan review. Cosmetic or routine operational changes do not materially alter response capability or governance.

Question 3 (CISM1-110)

Correct answer: B - Business-impact thresholds and a defined handoff and coordination process for crisis activation.

Readiness requires explicit impact-based triggers and coordination between incident and crisis structures. Activating crisis management for every alert is disproportionate, assigning permanent crisis leadership to a technical role may conflict with enterprise authority, and tool instructions do not resolve the integration gap.

Question 4 (CISM1-111)

Correct answer: D - Establish an enterprise response framework with common governance, severity principles, interfaces, and accountable owners.

An enterprise framework reconciles authority and escalation while allowing supporting plans to retain necessary operational detail. Uncoordinated local criteria perpetuate ambiguity, one technical procedure cannot cover distinct environments, and internal audit should remain independent rather than assume incident command.

Question 5 (CISM1-112)

Correct answer: C - Response and recovery priorities may fail because prerequisite services are not identified.

Unknown dependencies can make stated recovery priorities unattainable and cause resources to be sequenced incorrectly. Log volume and support cost are separate concerns, while disaster classification is not an inevitable result of the missing dependency data.

Question 6 (CISM1-113)

Correct answer: A - Use time-sensitive impact criteria that raise priority during enrollment windows.

Business impact can vary over time, so readiness criteria should account for known peak periods. Annual averages can obscure intolerable short-term impact, permanent maximum priority wastes resources, and server count is not a measure of business consequence.

Question 7 (CISM1-114)

Correct answer: B - A recovery point objective based on acceptable dispatch-data loss.

The recovery point objective expresses the acceptable amount of data loss and complements the approved recovery time objective. Ticket metrics, alert volume, and exercise duration do not define the business's data-recovery tolerance.

Question 8 (CISM1-115)

Correct answer: D - To sustain priority business activities during containment and service restoration.

Business continuity sustains prioritized activities during disruption and should operate in coordination with containment and recovery. It does not own forensic work, activate for every event, or replace the incident response process.

Question 9 (CISM1-116)

Correct answer: A - Develop and test a workaround without the likely failed dependency.

A viable continuity measure must avoid dependencies likely to be unavailable in the same incident and must be tested. The proposed spreadsheet process still relies on compromised identity and email, changing a rating does not fix it, and a blanket ban on manual work may undermine continuity objectives.

Question 10 (CISM1-117)

Correct answer: C - Define impact- and duration-based triggers that preserve the six-hour business tolerance.

Activation criteria should use business impact and expected duration early enough to stay within tolerance. Waiting for permanent loss is too late, a five-minute trigger may be disproportionate, and individual discretion produces inconsistent activation.

Question 11 (CISM1-118)

Correct answer: B - Revise the recovery sequence to restore prerequisite services before the publishing application.

Technology recovery must follow actual dependencies; otherwise the prioritized application cannot operate. Customer visibility does not override prerequisites, identical objectives are not automatically justified, and business priorities require accountable business input rather than only technical ownership.

Question 12 (CISM1-119)

Correct answer: D - End-to-end validation of prioritized services, data integrity, interfaces, and recovery objectives.

Starting infrastructure does not prove that business services are usable. End-to-end validation tests functionality, data, dependencies, and objectives. Configuration inventories and backup schedules provide supporting evidence, while seating plans do not validate technology recovery.

Question 13 (CISM1-120)

Correct answer: A - Documented restoration sequences, dependencies, responsibilities, and validation criteria.

Restoration sequences, dependencies, owners, and validation criteria translate recovery priorities into executable action. Routine ticket history and personal preferences do not provide that structure, and simultaneous recovery ignores differentiated criticality and dependencies.

Question 14 (CISM1-121)

Correct answer: B - Include data sensitivity, service criticality, trust impact, scope, and urgency in severity criteria.

Multidimensional criteria capture the potentially severe integrity and trust consequences of a code-signing compromise. Hardware value and device count are incomplete proxies, undocumented judgment reduces consistency, and automatically assigning maximum severity ignores actual scope and impact.

Question 15 (CISM1-122)

Correct answer: C - Documented thresholds based on impact, affected information, operational risk, and applicable obligations.

Documented, impact-based thresholds support consistent and timely escalation to the right stakeholders. Waiting for root cause can delay necessary action, employee requests alone are not reliable criteria, and escalating every alert overwhelms decision makers.

Question 16 (CISM1-123)

Correct answer: A - Separate category and severity, then map both to response requirements.

Category describes the nature of an incident, while severity reflects impact and urgency; mapping both to response needs routes the right specialists. Platform-specific levels become unwieldy, repair time omits legal and business impact, and wider distribution does not correct ambiguous classification.

Question 17 (CISM1-124)

Correct answer: D - Map competencies to roles and train identified gaps.

The exercise identified cross-functional role gaps, so competency mapping and targeted training directly improve readiness and resilience. Technical training for executives is misaligned, wholesale replacement is unsupported, and narrowing exercises would conceal the same coordination weaknesses.

Question 18 (CISM1-125)

Correct answer: B - Vary realistic scenarios and injects to test objectives, decisions, dependencies, and unexpected developments.

Varied, objective-driven exercises reveal whether participants can apply plans under changing conditions rather than memorize a script. Removing documentation, relying on one technical speed metric, or excluding business leaders weakens evaluation of management coordination.

Question 19 (CISM1-126)

Correct answer: C - A facilitated tabletop exercise using progressive business and stakeholder injects.

A facilitated tabletop safely tests leadership judgment and coordination through evolving scenarios. An unannounced shutdown creates unnecessary operational risk, a contact review has narrow scope, and a vulnerability scan tests controls rather than incident decision making.

Question 20 (CISM1-127)

Correct answer: A - Objective-based observations, identified gaps, accountable corrective actions, and retesting criteria.

Exercise value comes from evidence against objectives and tracked improvement actions. Attendance alone does not demonstrate capability, suppressing weaknesses prevents learning, and completing an exercise does not by itself validate the plan.

Question 21 (CISM1-128)

Correct answer: B - To identify incidents and establish their initial priority and routing.

Triage determines whether an event or alert meets incident criteria and sets an initial priority and route. Root cause, public disclosure, and full restoration occur later or only when circumstances require them.

Question 22 (CISM1-129)

Correct answer: D - The medication-order changes, because potential integrity and patient-safety impact require urgent assessment.

At triage, potential patient-safety and clinical-integrity impact outweighs a high volume of successfully blocked scans. Equal treatment ignores business consequence, and delaying assessment until regular staffing returns could allow serious harm.

Question 23 (CISM1-130)

Correct answer: C - Establish well-publicized, monitored reporting channels with defined intake and escalation procedures.

Central, monitored channels and defined intake ensure timely routing and consistent oversight. Personal messaging remains fragile, requiring proof discourages early reporting, and business managers should not conduct preliminary investigations that can delay or contaminate response.

Question 24 (CISM1-131)

Correct answer: A - Safely stabilize the process while preserving evidence where feasible.

Immediate life and operational safety takes priority, while coordinated documentation and feasible evidence preservation should continue. Leaving hazardous behavior active is unacceptable, undocumented erasure can destroy evidence, and safety authority remains with the organization rather than a vendor.

Question 25 (CISM1-132)

Correct answer: C - Use independent investigators and coordinate authorized access with legal and HR.

Potential insider involvement requires independence, controlled access, and coordination with legal and personnel functions to protect evidence and due process. Self-investigation creates a conflict, consent is not the governing condition, and public accusation before validation is premature and harmful.

Question 26 (CISM1-133)

Correct answer: B - Evidence integrity may be challenged because custody was undocumented.

Uncontrolled copying and missing handling records weaken confidence in evidence integrity and provenance. This does not predetermine root cause, create a disaster by definition, or by itself justify changing a business recovery objective.

Question 27 (CISM1-134)

Correct answer: D - Coordinate with legal counsel on preservation, interview, privilege, and documentation requirements.

Anticipated litigation makes early legal coordination important for preservation, interviews, privilege, and defensible documentation. Ad hoc retention risks spoliation, immediate broad notification may be premature, and deleting records without approved preservation guidance can create legal and evidentiary harm.

Question 28 (CISM1-135)

Correct answer: B - Balancing ongoing harm, safety, business impact, evidence, and recovery needs.

Containment is a risk-based management decision balancing harm reduction with operational, safety, evidentiary, and recovery consequences. Personal preference, procedure length, and historical use alone do not establish suitability for the current incident.

Question 29 (CISM1-136)

Correct answer: A - Isolate the connection, preserve records, and activate the authorized shipment workaround.

Confirmed ongoing corruption supports prompt, authorized isolation while evidence and continuity measures address secondary needs. Waiting permits further harm, rebuilding before stopping the source reverses the proper sequence, and the organization retains authority for protecting its environment.

Question 30 (CISM1-137)

Correct answer: C - Use time-bound compensating controls and track a permanent replacement.

Long-term containment should be risk-approved, monitored, time-bounded, and linked to permanent remediation. Restoring exposure discards protection, silent permanent acceptance bypasses accountability, and withholding the limitation prevents informed business decisions.

Question 31 (CISM1-138)

Correct answer: D - Issue an approved factual holding statement with response actions and update channels.

At this early phase, a coordinated holding statement addresses stakeholder needs using verified facts and promises controlled updates. Confirming rumors or publishing hypotheses spreads unverified information, while indefinite silence can worsen confusion during a visible disruption.

Question 32 (CISM1-139)

Correct answer: A - Engage legal and privacy stakeholders to map verified facts to applicable notification requirements.

Notification analysis should begin promptly and use verified facts against the obligations that actually apply. A universal deadline is unreliable, asserting harm before evidence is premature, and waiting for full root cause can cause required assessment or notification windows to be missed.

Question 33 (CISM1-140)

Correct answer: B - Use verified facts and tailor approved updates to each audience's decision needs.

Communications should remain factually consistent while being tailored to the decisions each audience must make. Identical detail can be unusable, independent estimates create contradictions, and purely reactive updates undermine coordinated oversight.

Question 34 (CISM1-141)

Correct answer: C - Escalate under the crisis plan and coordinate operational, executive, regulatory, and public communications.

The expansion into emergency service disruption crosses into enterprise crisis coordination and requires broader, controlled communication. Waiting for root cause delays leadership action, individual media responses risk inconsistency, and operational consequences do not end the underlying incident.

Question 35 (CISM1-142)

Correct answer: D - Revoke unauthorized tokens, remediate the weakness, and validate removal of persistence.

Eradication must address all known persistence paths and the enabling weakness before recovery. Removing only the visible extension is incomplete, delaying token revocation preserves unauthorized access, and separating a causal artifact into routine support would create premature closure.

Question 36 (CISM1-143)

Correct answer: A - To verify service functionality, integrity, security, and required business outcomes.

Recovery validation provides assurance that the service is usable, trustworthy, secure, and fit for business use at that phase. It cannot prove zero recurrence, does not replace monitoring, and business acceptance remains an organizational responsibility.

Question 37 (CISM1-144)

Correct answer: B - The business owner and incident authority, after agreed recovery criteria are met.

Return to normal requires authorized business acceptance and evidence that data integrity and recovery criteria are met. Technical availability alone is insufficient, a supplier does not own the business risk decision, and reaching the time objective does not excuse unresolved integrity discrepancies.

Question 38 (CISM1-145)

Correct answer: C - Restore service gradually with enhanced monitoring for recurrence.

Controlled restoration with enhanced monitoring provides assurance that recovery remains effective and detects recurrence. Disabling logs removes visibility, immediate demobilization is premature, and waiting for elimination of every enterprise risk is neither feasible nor proportionate.

Question 39 (CISM1-146)

Correct answer: B - Reassess the risk, revise procedures, train affected roles, and test a new scenario.

The post-incident phase should convert new threat knowledge and observed behavior into reassessed risk, improved procedures, role-based training, and tested capability. Leaving assumptions unchanged forfeits learning, relying only on technology ignores the decision failure, and banning voice communication is disproportionate.

Question 40 (CISM1-147)

Correct answer: D - Examine process, design, oversight, and contributing conditions while handling individual accountability through appropriate channels.

A post-incident review should uncover systemic causes and conditions that allowed the error, while personnel matters follow established processes. Canceling forfeits learning, blame-first review discourages candor, and excluding process owners removes people needed to improve the system.

Question 41 (CISM1-148)

Correct answer: A - The lifecycle process failed to establish ownership, monitoring, and effective testing.

The failed ownership, monitoring, and testing process explains why an expected lifecycle event caused the incident. User impact and call volume are symptoms, while server restarts are response actions rather than the underlying cause.

Question 42 (CISM1-149)

Correct answer: C - A tracked corrective-action process with owners, deadlines, validation, and exception governance.

Lessons become improvements only when actions are assigned, prioritized, completed, and independently validated or formally accepted as residual risk. Closure based on elapsed time, unreviewed vendor assertions, and meeting notes alone do not demonstrate remediation.

Question 43 (CISM1-150)

Correct answer: D - Trends in impact, response times, recurrence, corrective-action aging, and recovery performance.

This balanced set shows business consequences, response effectiveness, repeated causes, remediation discipline, and recovery performance. Alert volume, labor hours, or closure counts alone can be misleading and do not show whether risk and capability are improving.